

ICS Cybersecurity Evaluation (401) Training

Supply Chain Exercise



Identify Supply Chain Threats.

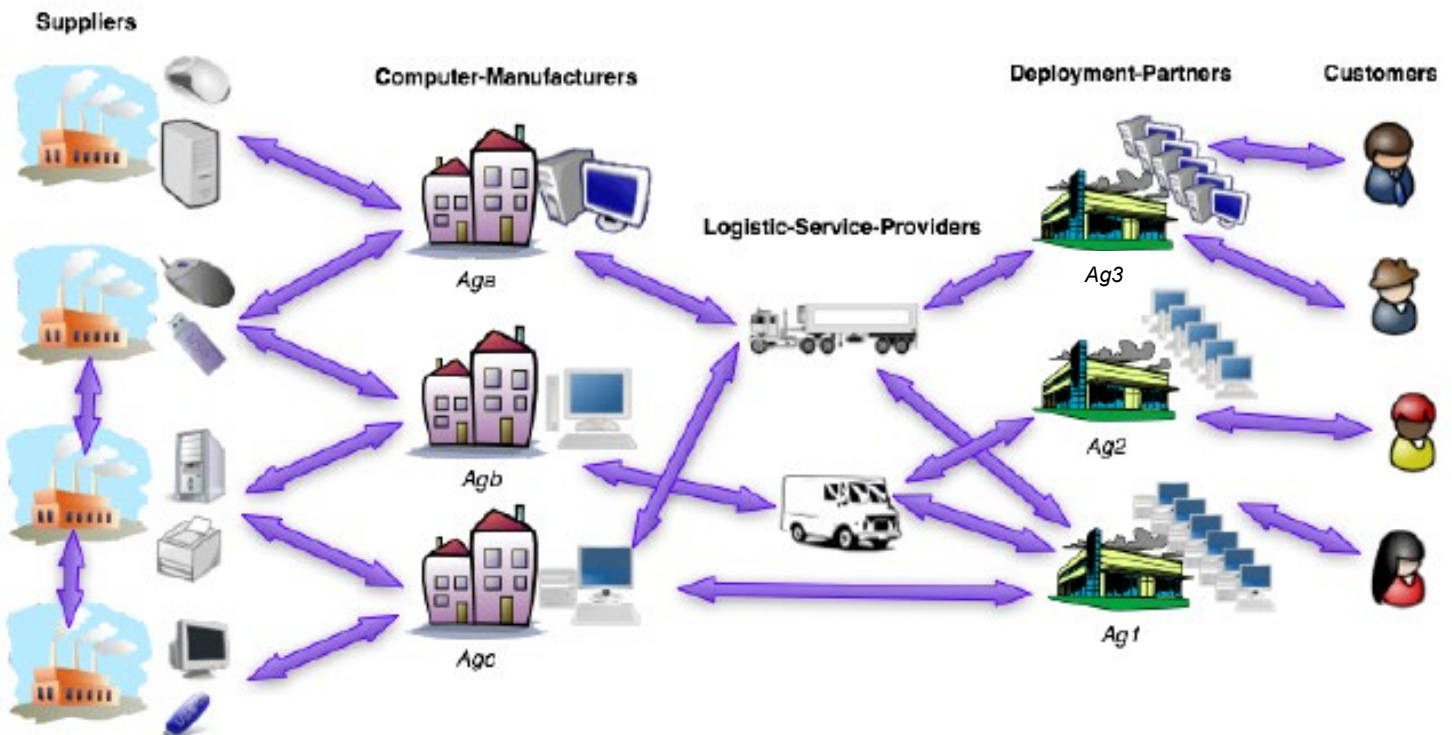
Time: 30 minutes

Resources: N/A

This does
NOT need to
be submitted
after
completion.

Instructions: Part 1

Using the image below to demonstrate a possible supply chain, at which point would it be the most useful to exploit the supply chain? Where could an adversary have the most widespread influence? How can an end-consumer, like you and your organization, protect and secure yourself? Will adding IoT to the supply chain make it easier or more difficult for hackers?



ICS Cybersecurity Evaluation (401) Training

Supply Chain Exercise

Instructions: Part 2

1. Read the articles below.
2. Identify the type and source of the attack.
3. Create a plan to prevent or respond to this particular supply chain attack.
4. Run your plan by co-workers at your organization to gain different perspectives and new context.

Article 1: The Big Hack: The Software Side of China's Supply Chain Attack

By Jordan Robertson and Michael Riley

<https://www.bloomberg.com/news/articles/2018-10-04/the-big-hack-the-software-side-of-china-s-supply-chain-attack>

Even as Amazon, Apple, and U.S. officials were investigating malicious microchips embedded in Supermicro server motherboards, Supermicro was the target of at least two other possible forms of attack, people familiar with multiple corporate probes say.

The first of the other two prongs involved a Supermicro online portal that customers used to get critical software updates, and that was breached by China-based attackers in 2015. The problem, which was never made public, was identified after at least two Supermicro customers downloaded firmware—software installed in hardware components—meant to update their motherboards' network cards, key components that control communications between servers running in a data center. The code had been altered, allowing the attackers to secretly take over a server's communications, according to samples passed around at the time among a small group of Supermicro customers. One of these customers was Facebook Inc.

"In 2015, we were made aware of malicious manipulation of software related to Supermicro hardware from industry partners through our threat intelligence industry sharing programs," Facebook said in an emailed statement. "While Facebook has purchased a limited number of Supermicro hardware for testing purposes confined to our labs, our investigations reveal that it has not been used in production, and we are in the process of removing them."

The victims considered the faulty code a serious breach. Firmware updates obtained directly from the manufacturer are usually assumed to be secure. Firmware is tailored to specific types of computer hardware and embedded directly into those parts, where it provides a narrow set of operating instructions. Detecting attacks at this level requires specialized security programs, so the code is rarely scanned for bugs. By corrupting Supermicro's update mechanism, the attackers were trying to get customers to infect themselves. While the chip and software attacks could be effective on their own, security experts say these approaches could also be used in concert, with the corrupted network cards amplifying the capabilities of the embedded chips.

In its denial that a chip attack had reached its server network, Apple did acknowledge to Bloomberg Businessweek that it had encountered malware downloaded from Supermicro's customer portal. Apple said the infection occurred in 2016, months after the events described by Facebook, and involved a single Windows-based server in one of the company's labs. The malware was on a network card driver, which is distinct from firmware and allows an operating

ICS Cybersecurity Evaluation (401) Training

Supply Chain Exercise

system and a piece of hardware to communicate. This was the reason Apple gave for dropping Supermicro as a supplier later that year. “As a matter of practice, before servers are put into production at Apple they are inspected for security vulnerabilities and we update all firmware and software with the latest protections,” Apple said in its statement to Businessweek. “We did not uncover any unusual vulnerabilities in the servers we purchased from Super Micro when we updated the firmware and software according to our standard procedures.”

However, a person familiar with Apple’s investigation says that around the time the company discovered malicious chips, it also found a more serious problem with network cards on Supermicro motherboards. Some Supermicro servers had network cards that came with outdated firmware, so the machines that were delivered to customers contained a critical security vulnerability that had been fixed in newer versions. This was potentially a third avenue of attack. Security experts say attackers could take advantage of a known firmware vulnerability in the same way they would use a more traditional software exploit. Once inside a target network, hackers could seek out servers with the dated code and easily infect them.

Questions

How did this supply chain attack happen?

How long did it take to identify it? Respond to it?

What could have been done differently? By technicians? By the manager? By the public relations people?

ICS Cybersecurity Evaluation (401) Training

Supply Chain Exercise

Article 2: SolarWinds Supply Chain Attack

By Matt Mathur

<https://raxis.com/blog/solarwinds-supply-chain-attack>

On December 8, 2020, FireEye disclosed that it had been breached by a sophisticated threat actor that had accessed some of its internally developed red team tools. On December 12, FireEye disclosed that this access, and access to many other companies, was accomplished through a supply chain attack against SolarWinds, a monitoring product that is deployed across a myriad of other organizations in the public and private sectors.

What we know: SolarWinds' Orion Platform versions 2019.4 HF 5 through 2020.2.1, released between March and June 2020, were affected by the supply chain attack. At present, we believe other versions are not affected.

Who was affected: In addition to FireEye, anyone running these SolarWinds versions should assume they have been compromised and should take immediate action to mitigate this exposure.

What to do:

Power down any SolarWinds Orion products that are running or have run versions 2019.4 HF 5 through 2020.2.1.

Upgrade to the SolarWinds Orion Platform version 2020.2.1 HF 1 immediately.

On Tuesday December 15, 2020, upgrade to SolarWinds Orion Platform version 2020.2.1 HF 2. This is a critical release that addresses the exposure.

If your company has used the affected versions, assume that the network has been breached and implement applicable incident response processes.

This was a far-reaching attack perpetrated by highly skilled threat actors. Evidence of the attack may be hard to detect, and Indications of Compromise (IOCs) may change over time as more information becomes available.

How did this happen:

SolarWinds was the victim of a sophisticated supply chain attack. Supply chain attacks target components that are trusted by their users in order to gain a foothold within an organization, product, or other target. This can happen to in-house software components, third-party libraries, or even in the manufacturing of devices. How the attack was deployed via the SolarWinds platform remains unclear, but multiple payloads were delivered via digitally signed updates from SolarWinds from March to May 2020 through the SolarWinds.Orion.Core.BusinessLayer.dll.

Technical Details:

The trojan placed on the system lays dormant for up to two weeks before making a DNS request to avsvmcloud[.]com to get the details of a Command and Control (C2) server.

Further communications with the C2 server masquerade as SolarWinds API traffic.

ICS Cybersecurity Evaluation (401) Training

Supply Chain Exercise

The trojan downloads multiple types of payloads, including a memory-only dropper that FireEye has named, "TEARDROP." A Cobalt Strike Beacon payload has also been detected.

After gaining a foothold, the attacker used remote access and conducted lateral movement using legitimate account credentials to establish persistence and levy ongoing attacks.

The attack prioritizes stealth and persistence, only using hostnames enumerated within the target environment and restricting traffic to mostly IP addresses from the target's country.

The attacker modifies files and scheduled tasks to drive remote execution and later reverts them back to their original contents in order to evade detection.

FireEye has released countermeasures for these threats, including Snort and Yara rules. For more specific details on the delivered malware, how it avoided detection, and other threat signatures, see the [FireEye blog post](#) detailing the attack. [1]

December 18, 2020 Update

Who was affected:

In addition to FireEye, Microsoft confirmed their systems were affected by the SolarWinds breach and have helped identify an additional 40+ customers of their own that have been affected. [2]

Additionally, RedDrip7 and Bambenek have put forth research into DNS records and other Indicators of Compromise to help people determine whether they have been compromised. [3]

However, anyone running these SolarWinds versions should still assume they have been compromised and should take immediate action to mitigate this exposure.

[1] <https://www.mandiant.com/resources/blog/evasive-attacker-leverages-solarwinds-supply-chain-compromises-with-sunburst-backdoor>

[2] <https://www.bleepingcomputer.com/news/security/microsoft-identifies-40-plus-victims-of-solarwinds-hack-80-percent-from-us/>

[3] <https://github.com/bambenek/research/tree/main/sunburst>

Questions

How did this supply chain attack happen?

How long did it take to identify it? Respond to it?

What could have been done differently? By technicians? By the manager? By the public relations people?